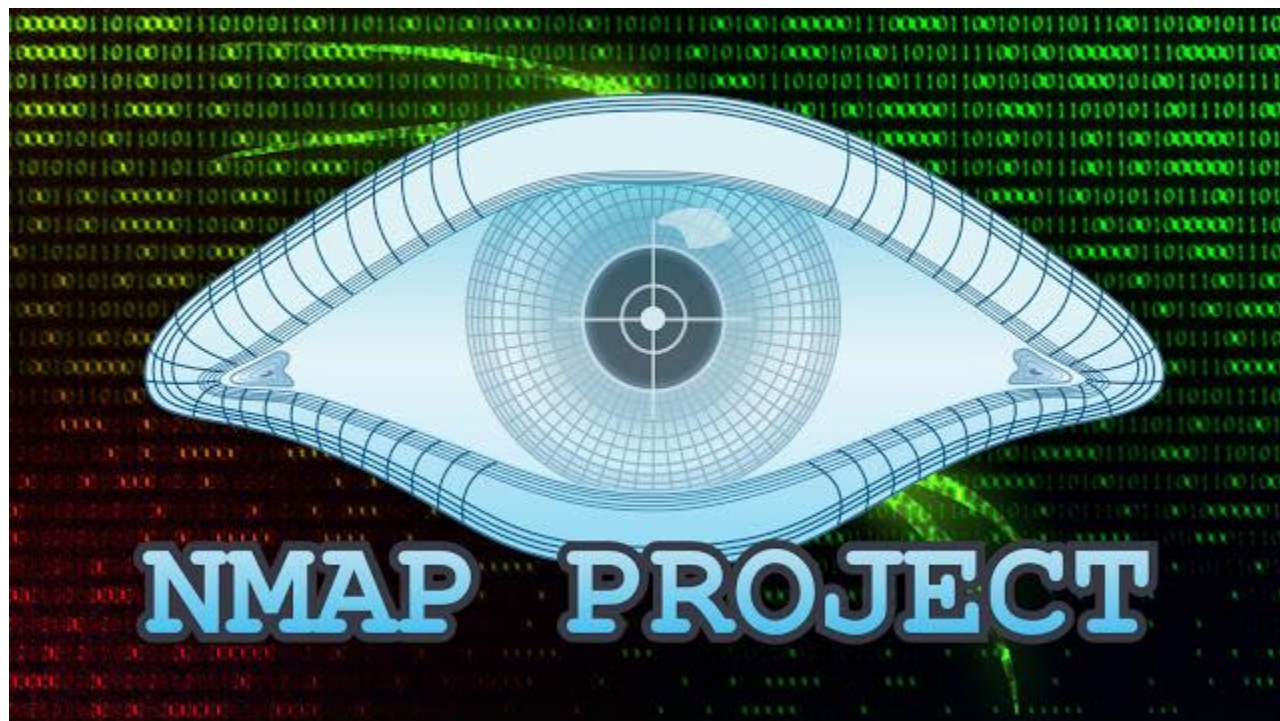


Hướng dẫn quét cổng (port) bằng Nmap

Nmap (Network Mapper) được Gordon Lyon giới thiệu lần đầu vào năm 1997, là một công cụ quét, theo dõi và đánh giá bảo mật hàng đầu, ban đầu nmap chỉ phát triển trên hệ điều hành linux, về sau có cả phiên bản dành cho các hệ điều hành khác như Windows, Mac OS,... đặc biệt nmap có một phiên bản GUI tên là Zenmap.



Trang chủ: <http://nmap.org/>

Tác giả: [Gordon Lyon](#)

Phiên bản: Nmap 7.01

Cấu trúc lệnh: *nmap <victim> [scan type] [options]*

Phần 1. Xác định mục tiêu:

Nmap có thể thực hiện quét trên một IP, dải Ip, domain hay là cả một danh sách. Ví dụ: thekalitools.com, thekalitools.com/24, 192.168.0.1; 10.0.0-255.1-254;...

Tùy chọn:

- iL <inputfilename>: Chọn danh sách mục tiêu
- iR <num hosts>: Chọn mục tiêu ngẫu nhiên.
- exclude <host1[,host2][,host3],...>: Bỏ qua các host.
- excludefile <exclude_file>: Chọn danh sách bỏ qua.

Phần 2. Lọc ra các máy chủ đang hoạt động:

Nếu mục tiêu của các bạn là một dải IP, thì việc này là vô cùng cần thiết. Hãy tưởng tượng, bạn phải scan từng port cho một dải lớp IP/24 khổng lồ có vài ngàn host, mà trong đó có những host không hoạt động mà bạn cũng phải chờ thì đúng là thảm họa. Để lọc ra các host đó, quá trình này ta gọi là Host discovery.

Về nguyên lý, nmap sẽ gửi một gói tin đến một port của mục tiêu, có thể là SYN-ACK ping, RST hay ICMP. Nếu host nhận được phản hồi, thì nmap sẽ cho host đó đang hoạt động và ngược lại.

Tùy chọn:

- sL: List Scan - Host discovery theo danh sách.
- sn: Ping Scan - Không scan port sau khi thực hiện.
- Pn: Bỏ qua Host discovery. Scan port trực tiếp.
- PS/PA/PU/PY[portlist]: Sử dụng TCP SYN/ACK, UDP hoặc SCTP tới port chỉ định. VD: PA80 là sử dụng TCP ACK cho port 80 khi discovery.
- PE/PP/PM: Thăm dò ICMP echo, timestamp, và netmask trả về.
- PO[protocol list]: IP Protocol Ping.
- n/-R: Không bao giờ / Luôn luôn thực hiện DNS resolution (mặc định là đôi khi tùy hứng).
- dns-servers <serv1[,serv2],...>: Chỉ định máy chủ DNS để resolver.
- system-dns: Sử dụng kết quả DNS resolution từ hệ thống.
- traceroute: Theo dõi từng máy chủ.

Phần 3. Kỹ thuật scan port:

Nmap có rất nhiều kỹ thuật scan khác nhau cho những yêu cầu khác nhau. Sau đây là một số kỹ thuật phổ biến được sử dụng trong Nmap:

Nhóm 1. TCP SYN/Connect()/ACK/Window/Maimon scan:

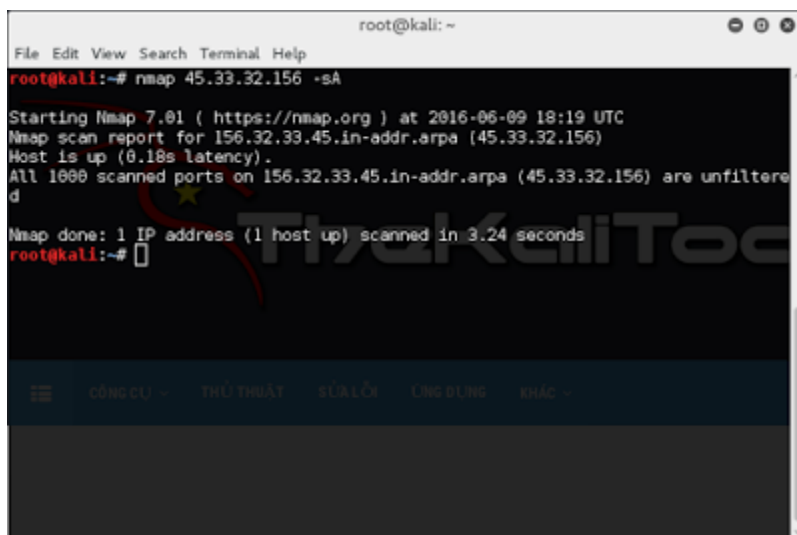
- **TCP SYN scan -sS:** nmap gửi một gói tin TCP-SYN tới 1 port của mục tiêu. Nếu nhận được ACK_SYN thì port đó đang ở trạng thái open, nmap sẽ gửi gói tin RST để đóng kết nối thay vì gửi ACK để hoàn tất quá trình bắt tay 3 bước (vì thế kỹ thuật này còn được gọi là half open scan). Nếu nhận được RST thì port đó ở trạng thái close. Nếu sau 1 số lần gửi mà không nhận được trả lời hoặc nhận được ICMP type 3 (unreachable error) thì port đó ở trạng thái filtered (đã bị firewall chặn).

```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# nmap 45.33.32.156 -sS  
  
Starting Nmap 7.01 ( https://nmap.org ) at 2016-06-09 18:17 UTC  
Nmap scan report for 156.32.33.45.in-addr.arpa (45.33.32.156)  
Host is up (0.19s latency).  
Not shown: 996 closed ports  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
9929/tcp  open  nping-echo  
31337/tcp open  Elite  
  
Nmap done: 1 IP address (1 host up) scanned in 3.05 seconds  
root@kali:~#
```

- **TCP connect scan -sT**: Kỹ thuật này được dùng khi user không có quyền truy cập raw packet để thực hiện SYN scan (thường thì với quyền root trên linux mới có thể sử dụng SYN scan). TCP connect scan sẽ sử dụng TCP stack của hệ điều hành để tạo ra 1 kết nối bình thường với mục tiêu, do thực hiện 1 kết nối đầy đủ nên kỹ thuật này dễ bị phát hiện bởi hệ thống log của mục tiêu do đó SYN scan thường được sử dụng nhiều hơn để tránh bị phát hiện.

```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# nmap 45.33.32.156 -sT  
  
Starting Nmap 7.01 ( https://nmap.org ) at 2016-06-09 18:18 UTC  
Nmap scan report for 156.32.33.45.in-addr.arpa (45.33.32.156)  
Host is up (0.18s latency).  
Not shown: 996 closed ports  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
9929/tcp  open  nping-echo  
31337/tcp open  Elite  
  
Nmap done: 1 IP address (1 host up) scanned in 14.20 seconds  
root@kali:~#
```

- **TCP ACK scan -sA**: Khác với hai kỹ thuật trên, kỹ thuật này sẽ gửi đi một gói tin TCP với flag ACK. Nếu nhận phản hồi là RST thì port đó không bị chặn (unfiltered) nếu không nhận được trả lời hoặc ICMP (type 3, code 1, 2, 3, 9, 10, 13) thì port đó bị firewall chặn (filtered).



```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# nmap 45.33.32.156 -sA  
  
Starting Nmap 7.01 ( https://nmap.org ) at 2016-06-09 18:19 UTC  
Nmap scan report for 156.32.33.45.in-addr.arpa (45.33.32.156)  
Host is up (0.18s latency).  
All 1000 scanned ports on 156.32.33.45.in-addr.arpa (45.33.32.156) are unfiltered  
  
Nmap done: 1 IP address (1 host up) scanned in 3.24 seconds  
root@kali:~#
```

Cả TCP SYN và TCP connect() đều cho ra một kết quả giống nhau. Thông thường ta dùng TCP SYN là hiệu quả nhất và không để lại log, nhưng nếu bạn không có quyền root thì ta mới phải sử dụng đến kỹ thuật TCP connect. Riêng TCP ACK dùng để kiểm tra firewall.

Nhóm 2. UDP scan:

- **UDP scan -sU:** nmap gửi gói tin UDP tới 1 port của mục tiêu nếu nhận được gói tin ICMP port unreachable error (type 3, code 3) thì port đó ở trạng thái close. Nếu nhận được ICMP unreachable errors (type 3, codes 1, 2, 9, 10, or 13) thì port đó ở trạng thái filtered. Nếu không nhận được gì thì port ở trạng thái open|filtered. Nếu nhận được gói tin UDP thì port đó ở trạng thái open.

Nhóm 3. TCP Null, FIN, and Xmas scans:

- **TCP NULL -sN:** Gửi gói tin TCP mà không kèm bất kỳ flag nào.
- **TCP FIN -sF:** Gửi gói tin TCP với flag FIN.
- **TCP Xmas -sX:** Gửi gói tin TCP với các flag PSH, URG và FIN.

Các kỹ thuật của nhóm này sẽ cho ra một kết quả giống nhau, tuy nhiên tùy theo nhu cầu bạn có thể chọn NULL, FIN hay là Xmas. Khi các gói tin được gửi đi nếu nhận được RST thì port ở trạng thái close, nếu nhận được các loại gói tin ICMP (type 3, code 1, 2, 3, 9, 10, or 13) thì port ở trạng thái filtered, còn nếu không nhận được gói tin trả lời thì port ở trạng thái open.

Phần 4. Lựa chọn port và thứ tự quét:

-p <port ranges>: Xác định các port mà bạn muốn quét (mặc định nmap sẽ quét theo danh sách port phổ biến). Bạn có thể thêm cả giao thức quét cho từng port bằng cách thêm chữ cái đầu của giao thức đó vào trước IP (T: TCP, U: UDP, S: SCTP, P: IP protocol) và ngăn cách bằng dấu phẩy (.). Ví dụ: ta dùng UDP cho port 53, 4000, dùng TCP cho port 1-100, 8000-8010 và port 80, ta gõ lệnh:

```
root@kali:~# nmap thekalitools.com -p U:53,4000,T:1-100,8000-8010,80
```

```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# nmap thekalitools.com -p U:53,4000,T:1-100,0000-8010,80  
Starting Nmap 7.01 ( https://nmap.org ) at 2016-06-09 18:26 UTC  
WARNING: Duplicate port number(s) specified. Are you alert enough to be using N  
map? Have some coffee or Jolt(tm).  
Nmap scan report for thekalitools.com (104.27.186.182)  
Host is up (0.033s latency).  
Other addresses for thekalitools.com (not scanned): 104.27.187.182  
Not shown: 110 filtered ports  
PORT      STATE SERVICE  
80/tcp    open  http  
Nmap done: 1 IP address (1 host up) scanned in 3.78 seconds  
root@kali:~#
```

Do chỉ có port 80 được mở trong các port yêu cầu scan nên nmap chỉ trả về 1 kết quả.

-F: Chế độ quét nhanh, giảm số port phổ biến cần quét xuống để rút ngắn thời gian.

-r: Quét theo thứ tự các port (mặc định nmap sẽ quét ngẫu nhiên).

--top-ports <number>: Thực hiện quét X port phổ biến nhất (X=munber).

--port-ratio <ratio>: Quét những port phổ biến hơn X% (X=ratio).

Phần 5. Thăm dò phiên bản dịch vụ:

-sV: Thăm dò và hiển thị phiên bản dịch vụ của từng port. Mặc định nmap chỉ lấy dịch vụ, và bỏ qua phiên bản dịch vụ của các port.

--version-intensity <level>: Chọn cường độ quét từ 0-9.

--version-light: Chọn cường độ là 2.

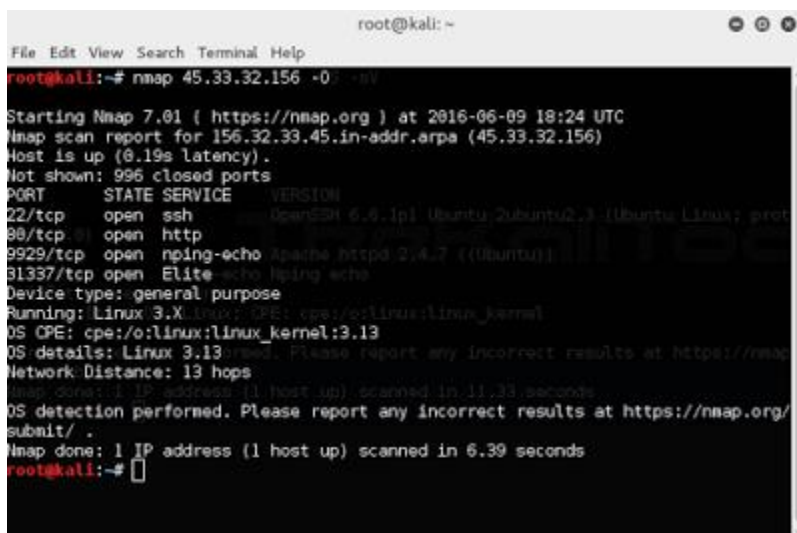
--version-all: Chọn cường độ quét là 9. Thử mọi cách quét.

```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# nmap 45.33.32.156 -sS -sV  
Starting Nmap 7.01 ( https://nmap.org ) at 2016-06-09 18:24 UTC  
Nmap scan report for 156.32.33.45.in-addr.arpa (45.33.32.156)  
Host is up (0.18s latency).  
Not shown: 996 closed ports  
PORT      STATE SERVICE      VERSION  
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.3 (Ubuntu Linux; prot  
ocol 2.0)  
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))  
9929/tcp  open  nping-echo   Nping echo  
31337/tcp open  tcpwrapped  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
Service detection performed. Please report any incorrect results at https://nmap  
.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 11.33 seconds  
root@kali:~#
```

Tuỳ theo yêu cầu, các bạn sẽ tăng dần cường độ cho đến khi tìm ra phiên bản dịch vụ mà bạn đang cần.

Phần 6. Thăm dò thông tin về hệ điều hành (OS):

- O: Bật chức năng quét thông tin OS.
- osscan-limit: Giới hạn quét thông tin OS.
- osscan-guess: Dự đoán thông tin OS.



```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# nmap 45.33.32.156 -O  
Starting Nmap 7.01 ( https://nmap.org ) at 2016-06-09 18:24 UTC  
Nmap scan report for 156.32.33.45.in-addr.arpa (45.33.32.156)  
Host is up (0.19s latency).  
Not shown: 996 closed ports  
PORT      STATE SERVICE      VERSION  
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu2.ubuntu2.3 (Ubuntu Linux; protocol 2.0)  
80/tcp    open  http         Apache/2.4.7 ((Ubuntu))  
9929/tcp   open  nginx-echo   Apache/nginx-echo 2.4.7 ((Ubuntu))  
31337/tcp  open  Elite-echo   nginx-echo  
Device type: general purpose  
Running: Linux 3.X (CPE: cpe:/o:linux:linux_kernel)  
OS CPE: cpe:/o:linux:linux_kernel:3.13  
OS details: Linux 3.13 (amd64). Please report any incorrect results at https://nmap.org  
Network Distance: 13 hops  
Nmap done: 1 IP address (1 host up) scanned in 11.33 seconds  
OS detection performed. Please report any incorrect results at https://nmap.org  
submit/.  
Nmap done: 1 IP address (1 host up) scanned in 6.39 seconds  
root@kali:~#
```

Ngoài ra, bằng trực quan các bạn cũng có thể đoán ra hệ điều hành đang chạy dựa vào các port đang mở hay các phiên bản dịch vụ mà không cần tốn thời gian cho phần này.

Phần 7. Tuỳ chỉnh thời gian:

- Tham số <time> trong các tuỳ chọn sau có thể là ms (mili giây), s (giây), m (phút) hay h (giờ).
- T <0-5>: Tốc độ scan tổng quát, tham số từ 0 là chậm đến 5 là nhanh.
 - min-hostgroup/max-hostgroup <size>: Kích thước các nhóm scan host.
 - min-rtt-timeout/max-rtt-timeout/initial-rtt-timeout <time>: Xác định thời gian thăm dò vòng.
 - max-retries <tries>: Số lần quét thử lại.
 - host-timeout <time>: Đặt thời gian timeout cho host discovery. Nếu vượt qua thời gian này, nmap xác định trạng host đang khởi động.
 - scan-delay/--max-scan-delay <time>: Đặt thời gian trễ (delay) giữa các lần quét.
 - min-rate <number>: Gửi các gói tin với các tốc độ không chậm hơn X gói tin mỗi giây (X=number).
 - max-rate <number>: Gửi các gói tin với tốc độ không nhanh hơn X gói tin mỗi giây (X=number).

Phần 8. Sử dụng các script trên nmap:

Thế mạnh của nmap là ngoài việc sử dụng như một công cụ phổ thông, nmap cho phép mở rộng bằng khả năng cho phép người dùng sử dụng các đoạn script viết sẵn (dạng .nse).

- script=<Lua scripts>: Chọn script bạn cần. Dùng dấu phẩy (,) để ngăn các phần danh sách thư mục, script file, script-categories.
- script-args=<n1=v1,[n2=v2,...]>: Nhập vào dữ liệu cho script.

--script-args-file=filename: Chọn file dữ liệu cho script.
--script-trace: Hiển thị tất cả những dữ liệu gửi và nhận.
--script-updatedb: Cập nhật database cho script.
--script-help=<Lua scripts>: Hiển thị trợ giúp của script lên cửa sổ lệnh.

Phần 9. Xuất kết quả:

-oN/-oX/-oS/-oG <file>: Xuất kết quả ra định dạng file text, XML, s|<rIpt kIddi3 hoặc Grepable.